

GoHa: PWA + Web Push Automation

Engineering handoff · 18 August 2026 · Continuation after an interrupted Codex implementation

Read this first. Migration `0016_famous_joseph.sql` is generated, reviewed and committed but **has NOT been applied** to production. The four tables it creates do not exist in the Neon database yet. Nothing in the push or worker surface can function until an owner applies it deliberately.

1. Why the delivery architecture changed

The original automation design (guides 00 to 07) delivered notifications through **Apple Shortcuts Personal Automations**. Each user's phone held a personal GoHa API token, ran four scheduled Shortcuts a day, and pulled from the Automation API.

That model works for one technical owner and fails for everyone else. A normal user would have to understand n8n, create Shortcuts, paste bearer tokens, and configure webhooks before receiving a single notification. It also cannot scale: a central n8n would need to hold every user's personal token.

Delivery is now **standards-based Web Push to an installed PWA**, scheduled centrally. The automation *logic* from the guides is unchanged and preserved. Only the transport moved.

Old versus new

Concern	Old (Shortcuts)	New (PWA + Web Push)
Trigger	Four Personal Automations per phone	Central n8n schedule, one instance for all users
Auth to GoHa	Each user's personal automation token, on their phone	One service credential (<code>AUTOMATION_WORKER_SECRET</code>)
Who is targeted	Whoever holds the token	Job rows; the caller never supplies a user id
Delivery	Shortcut renders a local notification	Server pushes to that user's registered devices
User setup	n8n, Shortcuts, token, webhook	Scan QR, Add to Home Screen, allow notifications

2. What Codex completed before the interruption

Codex's own status said implementation was largely complete and that it still owed a full validation pass. The audit found the code in **better** shape than that status implied: typecheck, lint, 500 unit tests and the production build all pass unmodified.

- **Schema and migration 0016:** `push_subscriptions` , `push_pairing_sessions` , `push_deliveries` , `automation_jobs` , the `automation_job_status` enum, and a `test` value added to `notification_kind` .
- **Web Push:** full RFC 8291 payload encryption and VAPID signing in `lib/push/web-push.ts` , with no runtime push dependency.

- **PWA:** `app/manifest.ts`, a push-only service worker at `public/sw.js`, a registration component, and icons.
- **QR pairing:** one-time, ten-minute, hashed pairing secrets that are setup *intent* only, never authentication.
- **Worker API:** `/api/internal/automation/jobs/*` with lease-based claim, payload, complete and fail.
- **Settings UX:** consumer-facing device onboarding, with the advanced Automation and API card gated to the owner email.
- **Documentation:** `docs/n8n-web-push-contracts.md` and `docs/PWA_WEB_PUSH_AUTOMATION_REVISION.md`, both complete and free of secrets.
- **Correctness fixes** to habit outcome, streaks, habit view, the progress heatmap and the review repository, with tests.

3. What Claude changed after the audit

Nothing in Codex's implementation was rewritten. The audit found no defect that warranted it: every gate passed, the security model held under inspection, and the architecture already matched the locked product decision. The only real gap was the undelivered documentation artifact.

- **Added this handoff PDF**, the deliverable Codex was preparing when it hit its usage limit.
- **Ran the full validation and security pass** Codex had deferred, including live read-only schema verification and a runtime probe of every new surface.

4. Migration 0016, review result

Verdict: additive and safe. Not applied.

Check	Result
Table drops	None
Column drops or type narrowing	None
Data deletion or backfill	None; every statement is CREATE or ADD
Existing tables touched	Only <code>notification_kind</code> , via <code>ADD VALUE 'test'</code>
Foreign keys	All to <code>user(id)</code> with <code>ON DELETE cascade</code> . <code>push_deliveries.subscription_id</code> uses <code>set null</code> , so removing a device keeps its delivery history
Multi-device support	Yes. <code>push_subscriptions</code> is unique on <code>endpoint</code> , not on <code>user_id</code>
Pairing semantics	One live session per user; a database CHECK caps lifetime at fifteen minutes; <code>consumed_at</code> enforces one-time use
Journal integrity	Entry 16 matches the file; <code>drizzle-kit check</code> passes; <code>db:generate</code> reports no drift

Applied state: the live database reports **16 of 17** migrations applied. 0016 is the outstanding one.

5. Multi-user status

Multiple accounts are supported, proven from the live database rather than inferred from migration history.

```
user_single_owner_uq present: no (dropped by migration 0014)
accounts in production:      3
```

Three real accounts coexist today. Every domain table has carried `user_id` with a cascading foreign key since migration 0000, and every repository filters by the session user, so this needed no structural change. Sign-up policy is a stored setting (`app_settings.signup_mode` , either `open` or `invite_only`) that only the owner can change.

6. Security model

Four credential types are kept in separate domains and are never interchangeable:

Credential	Purpose	Held by
Automation token	Developer and API integration, per user	Owner, in n8n or a terminal
Push subscription	A device's notification destination	GoHa database; the browser holds the endpoint
Pairing secret	Temporary device-onboarding intent	QR fragment, ten minutes, one use
Worker secret	Service-to-service auth for central n8n	Vercel environment and the n8n credential only

Findings

- **Pairing is not authentication.** Consuming a pairing session requires an independently authenticated session *and* that the session belongs to the pairing's owner. A wrong-account scan is refused with a message naming which account to sign into.
- **Replay is closed.** The secret is consumed atomically *before* the subscription write, so two phones racing the same QR cannot both succeed.
- **The QR carries no bearer token.** It carries a one-time setup secret in a URL fragment, exchanged for a short-lived HttpOnly cookie.
- **Subscription takeover is closed.** `endpoint` is globally unique; an endpoint already owned by another account is refused rather than reassigned.
- **Worker isolation.** The worker never supplies a user id. It claims leases and must present the lease id to read a payload, so it cannot enumerate other users' jobs.
- **Fails closed.** With `AUTOMATION_WORKER_SECRET` unset, the internal API returns 401. Verified at runtime.
- **No secret leakage.** `VAPID_PRIVATE_KEY` and `AUTOMATION_WORKER_SECRET` appear only in `server-only` modules and are absent from the built client bundles. Logs record error class names only, and the pairing

route never logs its body.

- **Service worker scope.** Root-scoped, served as JavaScript with `no-store`, and notification URLs are forced same-origin before navigation.

7. n8n worker contract

```
Authorization: Bearer <AUTOMATION_WORKER_SECRET>
```

```
POST /api/internal/automation/jobs/claim      { "limit": 1..N } -> jobs[] + leaseId
GET  /api/internal/automation/jobs/{id}      header: x-goha-job-lease: <leaseId>
      -> action:"process" + payload + fallbackNotification, or action:"skip"
POST /api/internal/automation/jobs/{id}/complete -> render and deliver push
POST /api/internal/automation/jobs/{id}/fail  -> report a pre-delivery failure
```

GoHa owns user identity, timezone, local date, eligibility, Sabbath, dedupe and every deterministic calculation. n8n orchestrates and optionally narrates through Gemini; if the model fails, the job already carries a deterministic `fallbackNotification`. Full request and response shapes are in `docs/n8n-web-push-contracts.md`.

Impact on existing n8n workflows

Workflow	Action
<code>goha-error-handler</code>	Keep unchanged
<code>goha-lib-guard</code>	Obsolete assumption: it expects a per-user automation token. Replace with the worker contract; do not design around it
<code>goha-test-caller</code>	Test only, old token model. Safe to delete once the worker flow is confirmed
Gemini and Gmail credentials	Keep both
Health Ping	Unchanged: fifteen-minute <code>/api/health</code> poll, email delivery, Sabbath-exempt

8. PWA and Web Push status

- **Manifest:** served at `/manifest.webmanifest`, standalone display, maskable and Apple touch icons present.
- **Service worker:** `push` and `notificationclick` handlers only. Every push shows a notification, satisfying the `userVisibleOnly` promise. No offline caching was added, deliberately.
- **Web Push:** RFC 8291 payload encryption with VAPID; subscribe, unsubscribe, multiple devices, a test notification, and cleanup of endpoints the provider reports as gone.
- **Permission:** requested only after an explicit user action. Unsupported browsers get an explanatory state rather than a dead button.
- **Connected state:** shown only when an active push subscription exists for that authenticated user. Creating a QR or a token does not count as connected. Disconnecting one device leaves the others intact.

Not yet verified on hardware. iOS requires the app to be added to the Home Screen before Web Push works at all. Unit tests and desktop browsers cannot prove that path. A real iPhone test over HTTPS is the acceptance gate.

9. Environment variables to configure

Set these in Vercel (Production) and mirror the worker secret into an n8n credential. The values are secrets and none are printed here or in any repository document.

Variable	Notes
VAPID_PUBLIC_KEY	One key pair, kept stable. Changing it invalidates every existing subscription
VAPID_PRIVATE_KEY	Server only. Never expose to the client
VAPID_SUBJECT	A <code>mailto:</code> or <code>https:</code> contact URI
AUTOMATION_WORKER_SECRET	32 to 256 characters, high entropy. Not a user's automation token

10. Owner actions, in safe order

1. `pnpm db:backup` , then confirm it with `pnpm db:restore-check` .
2. Review `db/migrations/0016_famous_joseph.sql` against section 4.
3. `pnpm db:migrate` to apply 0016.
4. Generate the VAPID pair and the worker secret; set all four variables in Vercel Production; redeploy.
5. Sign in on desktop, then Settings, then Connect your iPhone, and generate the QR.
6. On the iPhone: scan, sign in, Add to Home Screen, open from the Home Screen, allow notifications, and send the test notification.
7. Store the worker secret as an n8n credential and point the scheduler at the four worker routes.
8. Retire the personal-token assumption in `goHa-lib-guard` and delete `goHa-test-caller` .

11. Known limitations

- Flexible habits (X times per week or month) still lack a period-level progress denominator, so `streak_risk` delivery is deliberately inactive and day-specific habit lists omit those cadences.
- Evening jobs do not infer a previous-day target if scheduling crosses midnight.
- Graveyard and review have no central worker schedule or Sabbath catch-up policy yet; long-form delivery remains email.
- Exactly-once push receipt is impossible. Retries are safe through the job and per-device ledgers, but no external provider offers a transactional receipt.

- The revised guide source files referenced by Codex were not present in the repository, so exact Gemini prompts and the graveyard and review schedules remain unverified.
- No offline-first caching. The service worker is intentionally push-only.

12. Verification performed

```
pnpm typecheck    pass
pnpm lint          pass
pnpm test          48 files, 500 tests, all pass
pnpm build         pass
pnpm db:check      pass
pnpm db:generate  no drift
```

```
Live read-only schema: singleton index absent, 3 accounts, 16 of 17 migrations
Runtime probe:         /iphone/setup 200, /manifest.webmanifest 200,
                       /sw.js 200 with correct content type and no-store,
                       worker API 401 without the secret,
                       pairing stage 400 on a malformed code, never 500
```

READY FOR MANUAL ENV + MIGRATION REVIEW

Code, tests and documentation are complete. Production data is untouched: migration 0016 is unapplied and no push or worker environment secrets are configured yet. Device testing follows once both are done.